Tutorial de Modelagem de Ameaças

Introdução à Modelagem de Ameaças

A modelagem de ameaças é um processo pelo qual potenciais ameaças, vulnerabilidades e riscos podem ser identificados, enumerados e priorizados; tudo a partir do ponto de vista de um atacante hipotético. O objetivo da modelagem de ameaças é fornecer aos defensores uma análise sistemática do perfil do provável atacante, dos vetores de ataque mais prováveis e dos ativos mais desejados por um atacante.

A modelagem de ameaças responde às quatro perguntas-chave a seguir:

1. O que estamos construindo? Compreender o sistema, seu contexto, componentes e suas interações, fluxo de dados, controles de segurança e dependências.

2. O que pode dar errado? Identificar ameaças e vulnerabilidades possíveis. Você pode usar técnicas como STRIDE, árvores de ataque ou correntes de morte.

3. O que vamos fazer sobre isso? Determinar e implementar medidas de segurança para proteger o sistema contra ameaças identificadas.

4. Fizemos um trabalho suficientemente bom? Validar as medidas de segurança e iterar o processo. A verificação pode ser feita por meio de métodos como revisão de código, testes de penetração e red team.

Abordagens da Modelagem de Ameaças

Existem quatro abordagens gerais para modelar ameaças:

1. Centrado em ativos: Esta abordagem começa identificando e classificando os ativos de um sistema, e então foca nas ameaças aos ativos.

2. Centrado no sistema (ou centrado na arquitetura): Esta abordagem foca no design e componentes do sistema, e suas interações. Identifica ameaças com base na superfície de ataque exposta pela arquitetura do sistema.

3. Centrado no atacante: Esta abordagem começa assumindo a perspectiva do atacante, suas habilidades, motivações e objetivos, e então identifica ameaças com base em quais partes do sistema o atacante provavelmente segmentaria.

4. Centrado em lista: Abordagens centradas em lista para modelagem de ameaças, usando ferramentas como o Padrão de Verificação de Segurança de Aplicações (ASVS) do Open Web Application Security Project (OWASP), fornecem uma lista de verificação sistemática e abrangente para avaliar a segurança de aplicações de software.

Matriz de Traçabilidade de Requisitos (RTM)

Uma Matriz de Traçabilidade de Requisitos (RTM) é um documento, geralmente na forma de uma tabela, que correlaciona quaisquer dois documentos baseados que exigem uma relação de muitos para muitos para verificar a completude da relação. É usada para acompanhar os requisitos e verificar se estão sendo atendidos. No contexto da modelagem de ameaças, ela é usada para mapear funcionalidades (casos de uso) a ameaças (casos de abuso) e suas mitig ações.

Aqui está um exemplo:

Use Caso	Caso de Abuse	Ameaças	Mitigações
Usuário Login.	O atacante obtém. usuário credenciais	Espionagem, Phishing, Brutal Forçar	Use HTTPS, implemente autenticação de dois fatores autenticação, Bloqueio de Conta
Registrar Novo Usuário	Attacker registra um falso conta	Identidade. Falsificação	Implemente CAPTCHA, Email verificação
Nota Criação	O atacante cria uma nota com conteúdo malicioso	Cross-Persistent-Scripting de Site (XSS)	Implemente codificação de saída, entrada validação
Redefinir Senha	O atacante redefine outro senha do usuário	Elevação de privilégio	Implementar uma senha mais segura mecanismo de redefinição
Usuário Logout/Desconectar	O atacante continua o sessão mesmo após o usuário logout/desconectar	Sequestro de sessão	Implementar sessão segura gerenciamento

O desafio

Para cada caso de uso, considere como ele poderia ser abusado ou quais vulnerabilidades podem existir. Isso pode ser devido a problemas no código em si ou a problemas arquitetônicos mais amplos. Considere vários tipos de vulnerabilidades, como ataques de injeção, autenticação quebrada, exposição de dados sensíveis, etc.

Uma vez você tenha criado seu/sua RTM, use-o para analisar o código e os diagramas fornecidos, e ver quantos vulnerabilidades potenciais que você pode identificar.

Este processo não apenas ajudará você a entender as ameaças e vulnerabilidades potenciais, mas também permitirá praticar modelagem de ameaças, que é uma habilidade crucial em cibersegurança

Depois de criar sua Matriz de Rastreamento de Requisitos, tente identificar o maior número possível de vulnerabilidades nesta aplicação. Use o OWASP Top 10 como guia e veja se consegue identificar ameaças que se enquadram em cada categoria. Certifique-se de considerar tanto o código quanto a forma como a aplicação está estruturada. Observe que algumas vulnerabilidades podem não ser imediatamente óbvias e podem exigir uma compreensão mais profunda de como os diferentes componentes da aplicação interagem entre si.

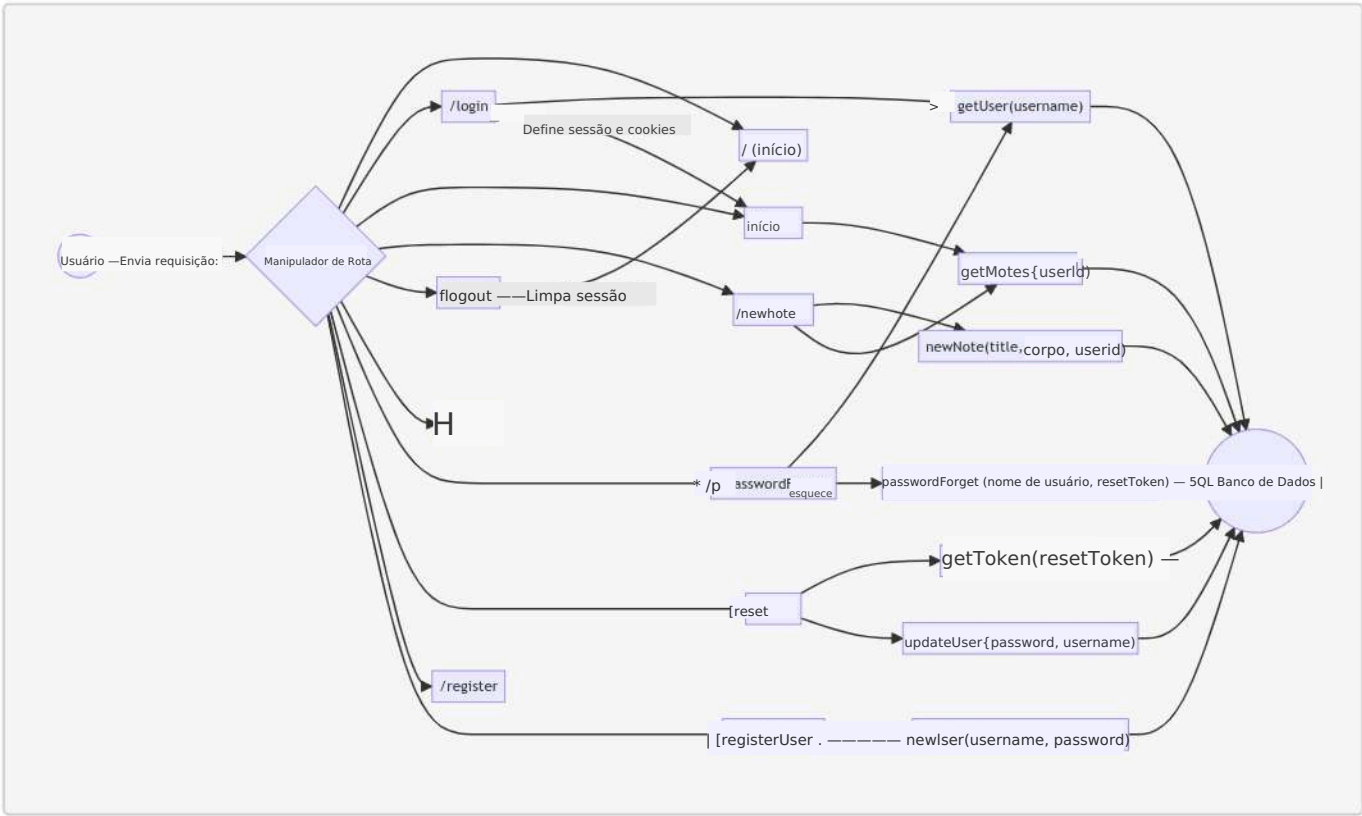
Este exercício testará sua capacidade de pensar como um atacante, que é uma perspectiva valiosa para qualquer profissional de segurança. Lembre-se de que o objetivo não é apenas encontrar vulnerabilidades, mas entender por que elas existem, como podem ser exploradas e como podem ser mitigadas ou eliminadas.

Quando você identificou o maior número possível de vulnerabilidades, compare suas descobertas com as de seus colegas. Todos encontraram os mesmos problemas ou houve alguns apenas que você percebeu? Isso pode ser uma ótima oportunidade de discussão e aprendizado.

Laboratório de aplicação Python Flask

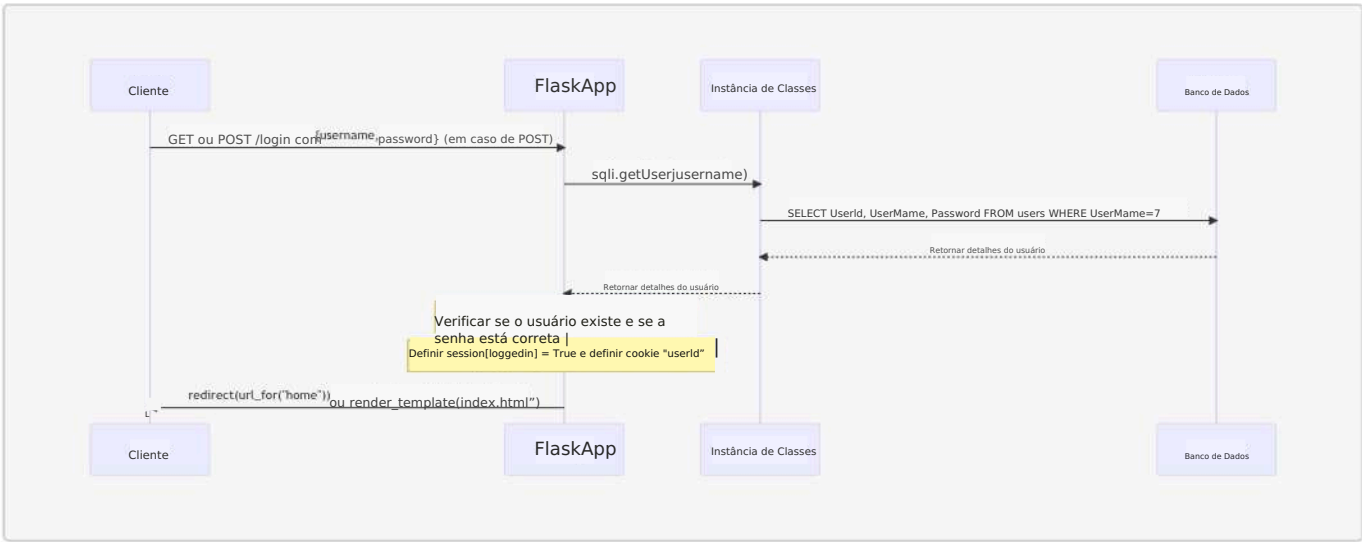
No contexto deste laboratório, você trabalhará com uma pequena aplicação Python Flask. Você pode encontrar o código-fonte aqui. Para cada funcionalidade da aplicação, diagramas e fluxogramas são fornecidos para lhe dar

entendimento do fluxo de dados e interações entre componentes.



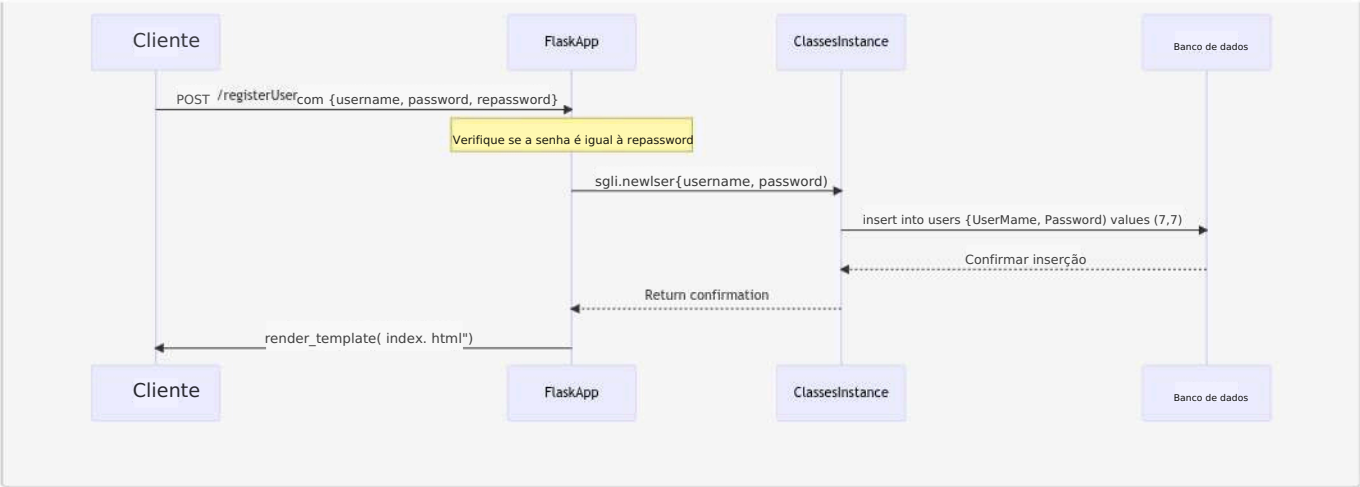
Diagramas de Sequência

Funcionalidade de login



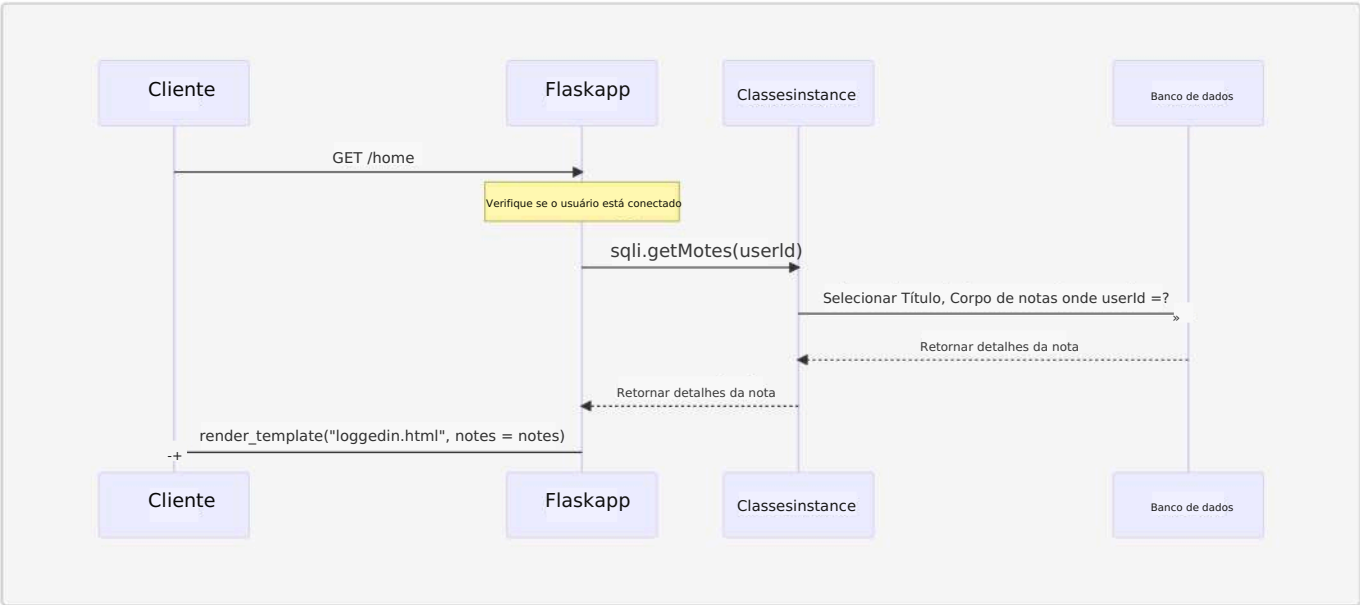
Essa funcionalidade permite que um usuário faça login em sua conta. O usuário envia seu nome de usuário e senha através do formulário de login. A função recupera as informações do usuário no banco de dados com base no nome de usuário fornecido. Ela verifica se a senha fornecida corresponde à senha armazenada para o usuário. Se as credenciais forem válidas, a função define a sessão como logada e retorna uma resposta com as informações do usuário e um cookie de sessão. Se as credenciais forem inválidas, a função retorna uma resposta redirecionando o usuário de volta à página de login.

Funcionalidade de Registrar Novo Usuário



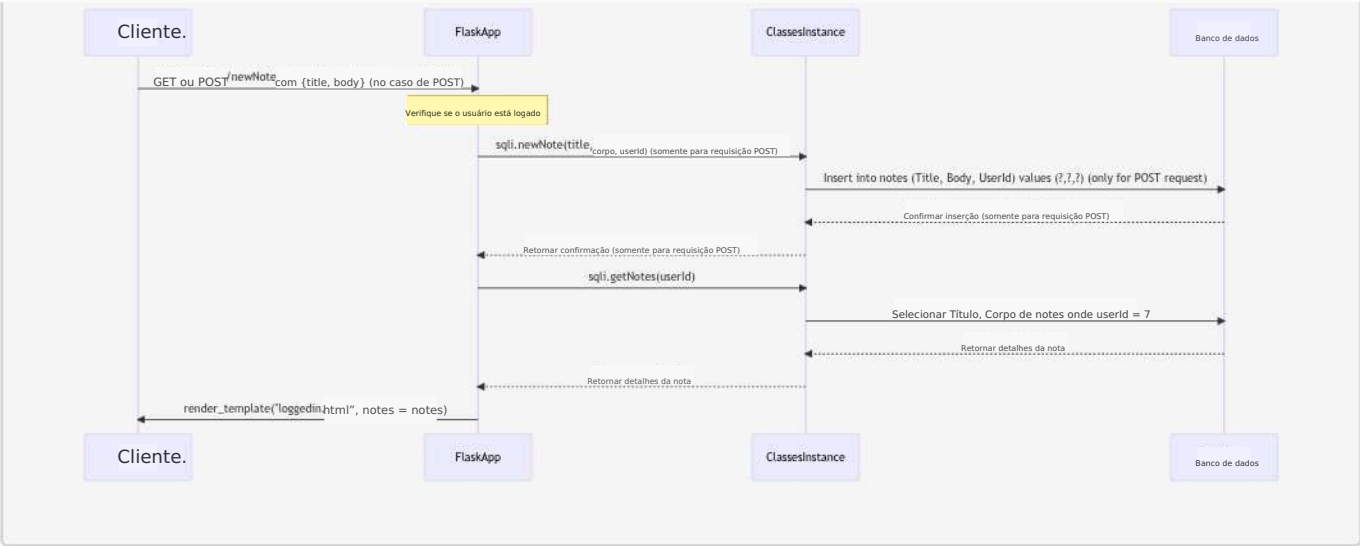
Essa funcionalidade permite que um usuário registre uma nova conta. O usuário fornece um nome de usuário desejado e senha. A função insere um novo registro na tabela "users" no banco de dados, armazenando o nome de usuário e a senha como uma nova entrada de usuário.

Funcionalidade da página inicial



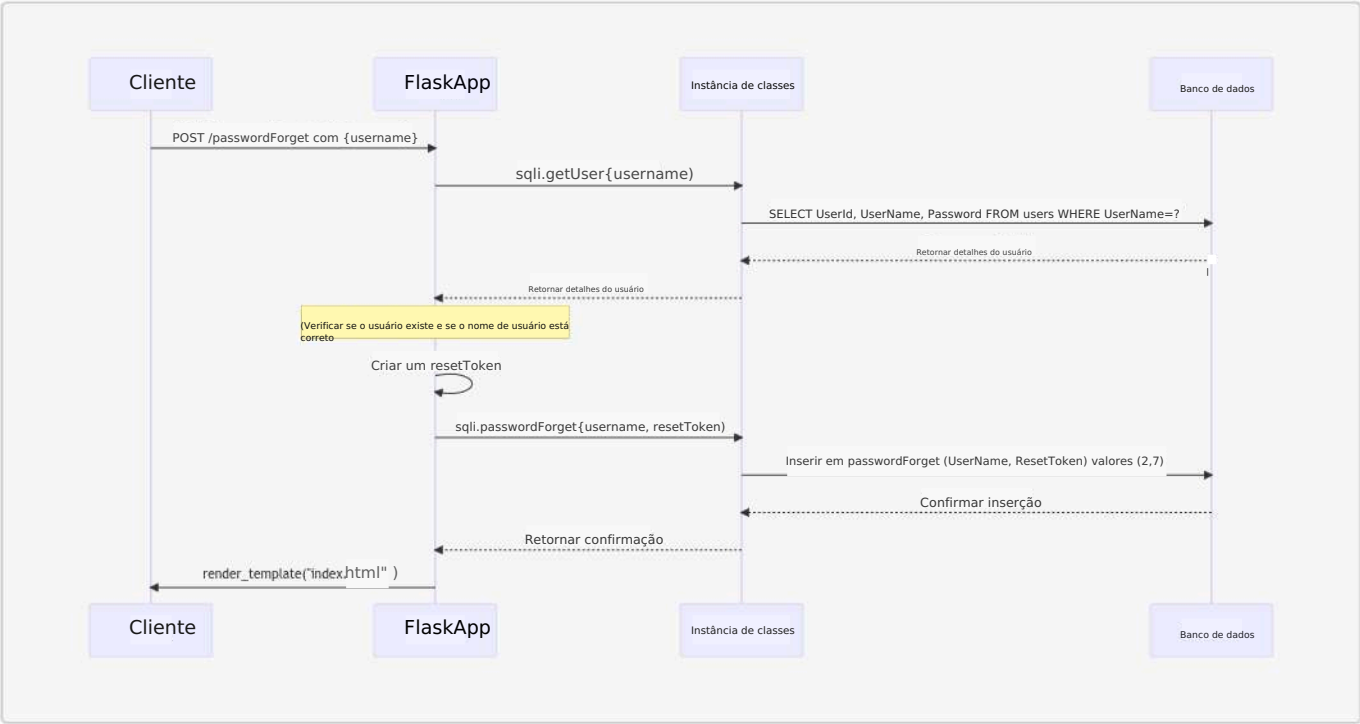
Essa funcionalidade é responsável por renderizar a página inicial após um login bem-sucedido. Ela recupera as notas associadas ao ID do usuário logado no banco de dados e as exibe na página.

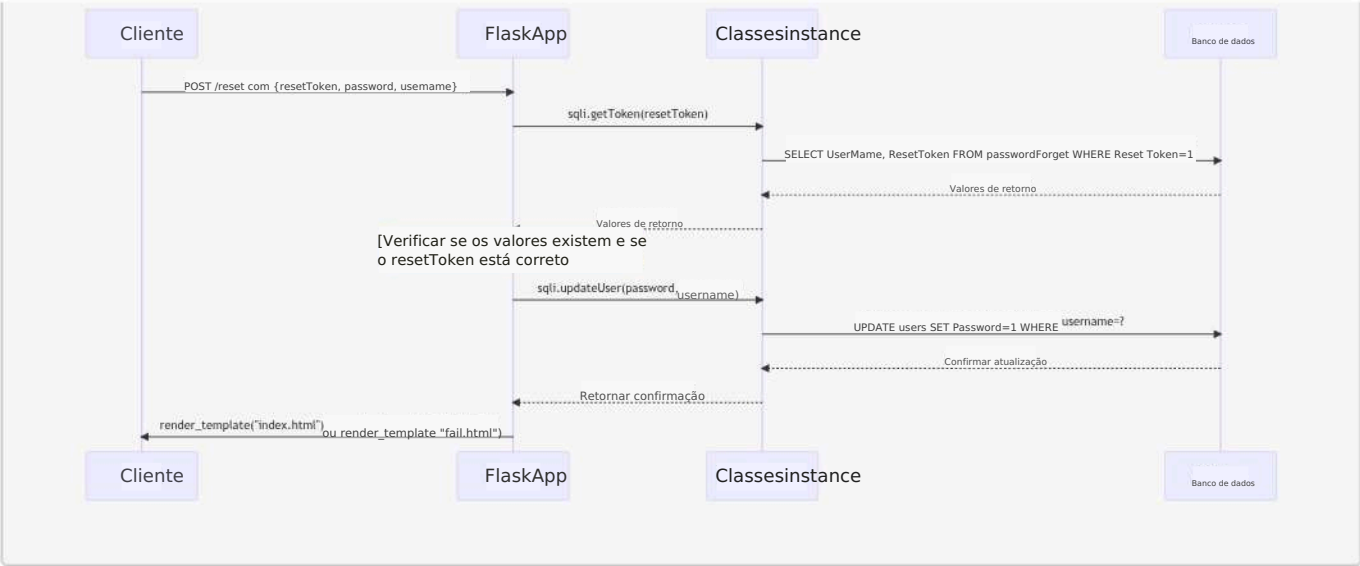
Funcionalidade de criação de notas



Essa funcionalidade permite que um usuário autenticado crie uma nova nota. O usuário fornece o título da nota, o corpo e o seu ID de usuário. A função insere um novo registro na tabela "notes" no banco de dados, armazenando os detalhes da nota associados ao ID do usuário.

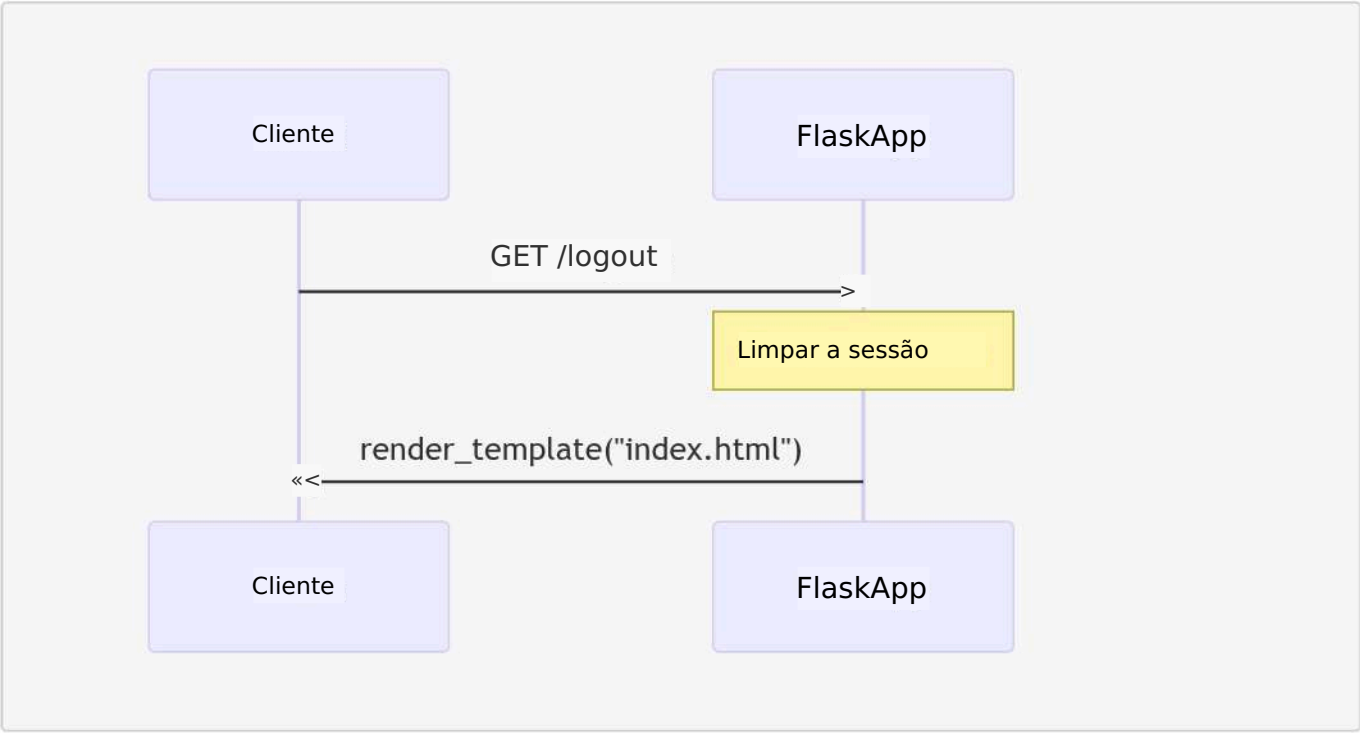
Funcionalidade de esquecer senha





Essa funcionalidade permite que um usuário inicie o processo de redefinição de senha. O usuário fornece seu nome de usuário, e um token de redefinição é gerado. A função insere um novo registro na tabela "passwordForget" no banco de dados, armazenando o nome de usuário e o token de redefinição para futura verificação durante o processo de redefinição.

Funcionalidade de logout do usuário



Essa funcionalidade faz logout do usuário atualmente conectado. Limpa a sessão, encerrando efetivamente a sessão autenticada do usuário. Após o logout, o usuário normalmente é redirecionado para a página de login ou para a página inicial.